June 16, 2025

Submitted electronically via Regulations.gov

Centers for Medicare & Medicaid Services
Department of Health and Human Services
Attention: CMS-0042-NC
Mail Stop C4-26-05
7500 Security Boulevard
Baltimore, MD 21244-1850

Re: RFI | Health Technology Ecosystem

Dear Secretary Kennedy:

On behalf of Citizen Health, I appreciate the opportunity to provide some responses to the questions in the Request for Information on the Health Technology Ecosystem (RIN 0938–AV68).

Citizen Health empowers patients (and caregivers working on their behalf) to have complete control of their health data: to use it and to share it with whomever, whenever, and wherever they want. With a particular focus on helping sick patients and their caregivers, the Citizen Health online platform democratizes health care by putting health information directly in the hands of patients - the stakeholders most motivated to collect it, use it, and share it liberally to save their own lives and the lives of others just like them. Our mission is to harness the power of data and shared experiences to provide relief to patients and families navigating rare and complex conditions.

The age of machine learning and artificial intelligence brings with it enormous potential to improve the lives of patients, reducing their burdens and improving their outcomes. At Citizen Health, we see a world where any patient, at any stage, with any condition, has immediate access to exceptional guidance on the best personalized actions to take at that point in time. We are hard at work building these tools for our users and communities of patients – and data is the fuel that powers these tools.

When we first started Citizen Health back in 2017 (at that time, it was known as Ciitizen), it was difficult for patients to easily obtain copies of all of their health and medical records, even though for more than 20 years the Health Insurance Portability and Accountability Act (HIPAA) Privacy Rule included a patient's right to be able to easily obtain complete copies of all of their medical and health plan records. We built a system from scratch that leverages this HIPAA right of access to obtain records on patients behalf, and it is still the predominant way that we obtain complete medical records for users of Citizen Health (including data not typically available through FHIR APIs or networks). Over the past 7+ years, the U.S. has made progress in providing patients with easier, digital access to electronic medical and health plan records, such as through electronic medical record certification standards mandating patient-facing FHIR APIs, periodic financial incentives from CMS to share data with patients, CMS requirements for patient access to health plan records (for plans under CMS purview), promulgation of the 21st Century Cures Act Information Blocking Rules, and enhanced enforcement of the HIPAA Privacy Rule, to name some key initiatives.

But there are still too many unnecessary obstacles to the use of this taxpayer supported, technological infrastructure by patients and caregivers, including through apps or platforms like Citizen Health working on their behalf – obstacles that HHS, using all of its various authorities, has the ability (and hopefully the courage) to address. **We urge you to review the comments of b.well Connect Health (a company we work with frequently on patient/caregiver access issues), the CARIN Alliance (a multistakeholder organization supporting patient and caregiver access to data and for which we are a member of the Board), Selfiie (a company that works with health information exchanges (HIEs) to facilitate the sharing of data held or exchanged by HIEs with patients) and Dr. Josh Mandel (https://joshuamandel.com/cms-rfi-collab/0) for more comprehensive assessments of some of the technological and policy obstacles they have seen or directly experienced and concrete suggestions for addressing them.** We will focus on our comments in this RFI on our direct experiences at Citizen Health, including some input from the patient advocacy organizations who are users of our platform, on some of the key questions in this RFI. For ease of use for CMS and ONC, we have created a table of all of the questions for which we had additional input, in the order in which they appear in the RFI.

We note that some of our recommendations involve clarification of, or issuance of additional guidance under, the HIPAA Privacy Rule, which is currently under the authority of the HHS Office for Civil Rights. HIPAA governs data sharing from some of the most important data holders in our ecosystem - providers and health plans and the vendors who serve them. Uncertainty about HIPAA's regulations and how they apply is frequently an obstacle to data exchange. An HHS strategy for improving patient access to their health information should include clarifications, guidance or even proposed modifications to HIPAA where needed to smooth the path to patient access. Our responses to the RFI include specific suggestions for updating HIPAA to meet modern data needs and capabilities.

Thank you again for the opportunity to provide these comments.

Sincerely,

Deven McGraw
Chief Regulatory and Privacy Officer, Citizen Health

Attachments (2)

RFI Questions

Ordinance	Section	Focus	Label	Question	Response
1.0	Patients and Caregivers	Patient Needs	PC-1	What health management or care navigation apps would help you understand and manage your (or your loved ones) health needs, as well as the actions you should take?	● Citizen Health works frequently with patient advocacy organizations to help these organizations better serve their patient populations. We posed this question and report the following responses: ○ Care management across clinical domains would be very valuable. At present, the caregiver or patient is responsible for keeping each specialist clinician in the loop on how other aspects of care are being managed (i.e., PCP and different specialist providers). This is an area where digital health can be very impactful. A universal portal that can summarize clinical progress notes and updates for the entire care team would be transformative for many caregivers / patients. ○ Health information should be able to be shared across institutions and health systems to minimize barriers to quality care, improve cohesiveness of the medical team, increase efficiencies, and decrease costs on repeated testing.
2.0	Patients and Caregivers	Patient Needs	PC-1a	What are the top things you would like to be able to do for your or your loved ones' health that can be enabled by digital health products?	● We posed this question to our partner patient advocacy organizations and report the following responses: ○ Push towards more proactive management of chronic and acute conditions. ○ Enabling health records to be accessible both to the families and to the providers at other institutions/health systems, including imaging and testing (not just the reports but the actual images themselves), so they do not have to be

Ordinance	Section	Focus	Label	Question	Response
					repeated at every hospitalization and doctor's visit.
3.0	Patients and Caregivers	Patient Needs	PC-1b	If you had a personal assistant to support your health needs, what are the top things you would ask them to help with? In your response, please consider tasks that could be supported or facilitated by software solutions in the future.	● We posed this question to our partner patient advocacy organizations and report the following responses: ○ Track and coordinate maintenance visits, keep each of the other specialists providers up to date on changes in care plans and med list, solicit recommendations for at dx that patient is at risk for but currently isn't being managed or evaluated for. ○ Scheduling appointments, identifying optimal specialists, learning opportunities to save costs and care. ● When patients are able to seamlessly collect all of their health (and wellness) information from all of the places where they've been seen, and ideally from all of their health-relevant apps and devices, they have at their fingertips the tools for: better self care, more seamless engagement of trusted caregivers, the ability to get more out of their frequently limited interactions with their clinical providers, and the agency to directly support (through contributions of data) research that matters to them and their families. ● Once this data is all in one place, technology developers who serve patients and caregivers can build tools that are designed to help patients understand their health conditions better, seek more optimal treatments, keep caregivers in the loop, and even have more meaningful interactions with providers as well as other patients like them. For

Ordinance	Section	Focus	Label	Question	Response
					example, Citizen Health, which gathers all of a patient's health information for benefit of the patient, is using AI and machine learning to develop easy ways for patients to query their data (and the data of other patients like them, with consent) to be able to better understand their health conditions, and to learn about treatments that other patients like them have received and what has been the experience. The ability to query records for relevant information will also help patients to complete intake forms (e.g., the dreaded clipboard, benefits application forms, fitness-for-work or duty assessments), which are not standardized (and probably never will be) and which frequently require detailed medical information. ● The ability to effectively serve patients and caregivers with data and tools that make the health-related aspects of their lives easier is the ultimate goal - and the primary obstacle has been the lack of easy, seamless, consistent complete access to data across multiple sites of care. ● For some historical context, see the work of the Commonwealth Fund to promote a Digital Health Assistant for patients with complex conditions (https://www.commonwealthfund.org/publications/journal-article/2019/jun/developing-digital-health-advisor-patients-complex-needs),
4.0	Patients and Caregivers	Patient Needs	PC-2	Do you have easy access to your own and all your loved ones' health information in one	● We posed this question to our partner patient advocacy organizations and report the following responses:

Ordinance	Section	Focus	Label	Question	Response
				location (for example, in a single patient portal or another software system)?	○ Yes, third party Citizen Health has enabled aggregation across domains which has been valuable. This has added value in clinical situations when prior imaging at other facilities during acute periods has enabled better clinical decision making. ○ No, our daughter has 10+ specialists across 8 institutions where the health records and information and results are not connected or communicating. We have to navigate that care, shared records amongst specialists.
5.0	Patients and Caregivers	Patient Needs	PC-2a	If so, what are some examples of benefits it has provided?	● Repeating here a relevant response from one of our patient advocacy group partners: Citizen Health has enabled aggregation across domains which has been valuable. This has added value in clinical situations when prior imaging at other facilities during acute periods has enabled better clinical decision making.
6.0	Patients and Caregivers	Patient Needs	PC-2b	If not, in what contexts or for what workflows would it be most valuable to use one portal or system to access all such health information?	● Today, patients who use Citizen Health, all of whom are medically complex patients, frequently see between 2-10 medical providers on a regular basis. Being able to access just data available from all of those provider portals (i.e., FHIR APIs) requires establishing and maintaining multiple connections. ● Portals also do not have all of the data that patients have a right to under HIPAA; consequently, to get complete data, patients also need to submit requests to medical record offices and to radiology and other image providers. Similarly, HIEs and national networks increasingly are sources of valuable data, but they are unlikely to be complete (for example, images are frequently absent, and participation in

Ordinance	Section	Focus	Label	Question	Response
					networks of ambulatory providers has historically been low). ● For most patients, having a single onramp or at least a single site for all of this data is critical.
7.0	Patients and Caregivers	Patient Needs	PC-2c	Were there particular data types, such as x-rays or specific test results, that were unavailable? What are the obstacles to accessing your own or your loved ones' complete health information electronically and using it for managing health conditions or finding the best care (for example, limitations in functionality, user friendliness, or access to basic technology infrastructure)?	● HHS (in particular, ASTP/ONC, CMS, and OCR) is to be applauded for increasing the amount of data for which there is a technical capability for patients to access (it's a separate question as to whether entities/organizations take full advantage of these technical capabilities and regularly expose all of this data to patient access - see comments below on issues with obtaining data from portals.) ● However, notwithstanding these efforts, there is still data that patients cannot access through automated means. (Compare USCDI v.1 & V4 (which, if deadlines aren't extended, will go into effect on January 1, 2026) with an attempt to define the entirety of the "designated record set," which is the data that patients have a right to under HIPAA https://www.ahima.org/media/ztqh1h2q/final-ehi-task-force-report.pdf). Among the data elements frequently missing from portals are: images (xrays, MRIs, EEG tracings); pathology reports; all clinical notes; genetic test results; ambulatory records from providers not using certified EMRs); results of functional tests; and social needs data. ● Even for data that should be available through portals/APIs, there are often significant obstacles that patients face in connecting apps to portals and maintaining those connections. (See the following

Ordinance	Section	Focus	Label	Question	Response
					resources from the CARIN Alliance, which describe the challenges to accessing data through FHIR APIs: https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/684318a6dfde5e7b2fab0f3f_CARIN%20AppForum_Challenges%20to%20Scale%20of%20User%20Choice%20Without%20Special%20Effort_6.5.25.pdf; https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/684319a14c893300be71bdcd_02%20Endpoint%20Discovery%20and%20Getting%20Started%20(6.5.25).pdf; https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/684319f357f39ee05872f32e_03%20Registration%20and%20Onboarding%20(6.5.25).pdf; https://cdn.prod.website-files.com/66635361bd8176cd6413cb12/68431a7c9e1a8892bd7fa658_04%20Standard%20APIs%20With%20Support%20and%20Related%20Enablement%20Services.pdf; see also comments to this RFI submitted by b.well Connected Health and the CARIN Alliance.)
8.0	Patients and Caregivers	Patient Needs	PC-3	Are you aware of health management, care navigation, or personal health record apps that would be useful to Medicare beneficiaries and their caregivers?	• There are a number of patient-facing applications designed to help patients of all types to access their health information. Please see the CARIN Alliance for the list of apps that have executed the CARIN Alliance App Code of Conduct as one example. • Federal policy should focus on data standards and assuring access and allow individuals to choose the apps that best meet their needs.

Ordinance	Section	Focus	Label	Question	Response
9.0	Patients and Caregivers	Patient Needs	PC-4	What features are missing from apps you use or that you are aware of today?	● Patients need medical information to populate a wide variety of intake forms (for example, new patient forms or even annual updates at existing providers, forms to register for school or for camps, applications for appropriate school placement for children with special needs, disability applications, etc.). ● Each organization/entity requiring medical information will have their own forms designed to meet their particular needs, and it would be a wasted effort to try to standardize these. ● If patient-facing apps had complete data, they could compete on their capabilities to help patients (or their caregivers) easily complete any type of form. ● Citizen Health is developing tools to ingest forms and, through AI and access to data in the patient's account, enable the generation of draft responses that can be validated by the patient prior to submission. Access to complete data by the patient will be critical to unlocking these capabilities.
10.0	Patients and Caregivers	Patient Needs	PC-4a	What apps should exist but do not yet? Why do you believe they do not exist yet?	● We posed this question to our partner patient advocacy organizations and report the following responses: ○ Universal patient portal with provider to provider to patient messaging capabilities and data sharing enablements. ○ Understanding costs of care and tests with your insurance, which does not exist because the medical charges/payment process is made to be far more complex than it needs to be and varies by insurance.

Ordinance	Section	Focus	Label	Question	Response
11.0	Patients and Caregivers	Patient Needs	PC-4b	What set of workflows do you believe CMS is uniquely positioned to offer?	● We applaud CMS's commitments to developing a provider directory that has up-to-date, working interoperability endpoints. ● We also applaud CMS' commitment to updating its Blue Button efforts to assure Medicare patients have access to CMS data. ● We believe CMS' most important role in facilitating interoperability is maximizing all of its authorities to assure that the entities under its authority are consistently adhering to existing federal policy. For example: ○ Using conditions of participation as another lever to assure provider compliance with information blocking requirements. ○ Requiring states to adopt and enforce interoperability requirements for Medicaid plans and providers.
12.0	Patients and Caregivers	Patient Needs	PC-5	What can CMS and its partners do to encourage patient and caregiver interest in these digital health products?	● We posed this question to our partner patient advocacy organizations and report the following responses: ○ Enable development, raise awareness of resources, encourage adoption. ○ Enable products that can extend across health systems and integrate records (HIPPA creates WAY too much of a barrier for this). ● The continued friction patients and caregivers experience in trying to get access to all of their health information, and being able to use and share that information to improve their care experience, is why uptake of digital health tools by patients and

Ordinance	Section	Focus	Label	Question	Response
					caregivers has lagged. When these issues are fixed, demand will follow. ● However, incentives for patients and caregivers like premium or co-pay discounts could also help improve awareness and interest. But such engagement is only sustained with true value in using the product - when the federal government uses its authorities to assure seamless access to complete data can occur, the private sector can do its job in producing products that patients find valuable.
13.0	Patients and Caregivers	Patient Needs	PC-5a	What role, if any, should CMS have in reviewing or approving digital health products on the basis of their efficacy, quality or impact or both on health outcomes (not approving in the sense of a coverage determination)? What criteria should be used if there is a review process? What technology solutions, policy changes, or program design changes can increase patient and caregiver adoption of digital health products (for example, enhancements to data access, reimbursement adjustments, or new beneficiary communications)?	● CMS should leave evaluation of digital health products - in terms of their usefulness and data policies - to patients. ● CMS can play a role in facilitating a market for patient-facing digital health tools by requiring transparency about data sharing policies. ● Any reviewing or approving of digital health tools should take care not to impose value judgements on patients. For example, at one point (and maybe still today), CMS Blue Button policies were hostile to apps that “sold data.” ● The transparent business model of Citizen Health is to collect license fees when patients consent to share their de-identified health information with commercial researchers (such consent is NOT required for patients to use Citizen Health for free, so the sharing of this data is truly voluntary). Citizen Health also shares a percentage of these fees with the patient, and with the patient advocacy group that the patient belongs to. We get positive feedback

Ordinance	Section	Focus	Label	Question	Response
					from our users about this aspect of our product. As long as licensing of data is fully transparent to users, and subject to their consent, it should not be a disqualifier for endorsement or acceptance by CMS or any other provider or health plan.
14.0	Patients and Caregivers	Patient Needs	PC-5b	What changes would enable timely access to high quality CMS and provider generated data on patients?	● This RFI is a joint effort from CMS and ASTP/ONC, but HIPAA clarifications through the Office for Civil Rights (OCR) are going to be needed to eliminate some persistent obstacles to patient access to data. ● Most entities that are rich sources of data for patients - providers and health plans - are governed by HIPAA. Consequently, when there is uncertainty about what HIPAA permits or requires, that uncertainty translates into friction for patients trying to seamlessly access their health information. ● Three key ways where uncertainty about HIPAA creates obstacles to patient access: ○ Entities who are “actors” under the Information Blocking Rules but who are business associates under HIPAA decline to share digital data with patients unless expressly permitted to do so by their business associate agreements, notwithstanding the expectations of the Information Blocking rules; and ○ Patients still face obstacles in obtaining data that is not available through portals or is not digital data (data still maintained in paper form), a process governed solely by HIPAA. Notwithstanding efforts to expand USCDI, there likely will always be additional data that patients

Ordinance	Section	Focus	Label	Question	Response
					have the right to access that will not be able to be made accessible through EMR portals. ○ Data holders participating in TEFCA and other national networks are reluctant to share records (payload) in response to individual access requests due to concerns about possible breach if the wrong record is sent or due to uncertainty about whether the request is a patient access request or an authorization by the patient to share with a third party. ○ There is uncertainty about whether TEFCA requires patients apps to share data back to the network in response to a patient access request. Under HIPAA, entities may not condition release of a patient's data on the patient agreeing to share data back; nevertheless, some TEFCA QHINs are promoting a policy that would require IAS providers to obtain patient consent for sharing records back to TEFCA as a condition of launching an IAS query for the patient's records. ● On January 21, 2021, OCR released a proposed rule making some modifications to HIPAA to facilitate patient access (RIN 0945-AA00). Those modifications were never finalized (likely due to the perception that the changes were only priorities of the prior administration). We submitted extensive comments in support of some of those modifications and sought important changes to others. Attached as Appendix A are excerpts from those comments relevant to bullets 1 and 2 above. CMS and ASTP/ONC should work with their colleagues at OCR to revisit that rulemaking and

Ordinance	Section	Focus	Label	Question	Response
					act promptly on changes that will help facilitate patient access to data. ● With respect to bullet 3 above, the CARIN Alliance and peer organizations supporting interoperability with patients submitted a letter to (then) ONC and OCR suggesting guidance regarding the application of the HIPAA breach notification rules - in particular, the low probability of compromise determination - in the context of sharing data across national networks in response to patient queries. (see link below) We have since met with OCR and ASTP/ONC on this matter, and strongly believe that additional guidance is both consistent with OCR's prior positions on this topic and would significantly ease the concerns of data holders about the possibility of sending wrong patient records in response to a patient query. https://cdn.prod.website-files.com/66635361bd8176cd6413cb24/66635361bd8176cd6413cc4d_CARIN_Final-Letter-to-OCR-re-Breach-Notification_07202022.pdf ● The CARIN Alliance has also appealed to ONC/ASTP and the Sequoia Project to clarify TEFCA policy regarding whether IAS providers must obtain patient consent to share records back in order to launch an IAS query for records on behalf of the patient. Because HIPAA has long prohibited such conditions on a patient's right of access, CMS should also work with OCR to issue clarification that the HIPAA Privacy Rule does not permit such a condition on patient access. Although OCR does not set TEFCA policy, and TEFCA is a voluntary network, stakeholders in TEFCA will refrain from adopting policies that undermine the ability of

Ordinance	Section	Focus	Label	Question	Response
					TEFCA to be used to meet HIPAA data sharing requirements.
15.0	Patients and Caregivers	Patient Needs	PC-6	What features are most important to make digital health products accessible and easy to use for Medicare beneficiaries and caregivers, particularly those with limited prior experience using digital tools and services?	● We posed this question to our partner patient advocacy organizations and report the following responses: ○ Frictionless patient facing side of the software. ○ Ability to access and share records, including images (not just the reports, but the actual images themselves). ● If the ability to connect to comprehensive data is strengthened, private sector apps will develop and compete on features to enable easy use by Medicare beneficiaries and their caregivers.
16.0	Patients and Caregivers	Patient Needs	PC-7	If CMS were to collect real-world data on digital health products' impact on health outcomes and related costs once they are released into the market, what would be the best means of doing so?	● Most apps would be willing to share such impact and outcomes data with CMS if asked. If such data were published, it would provide added incentive for those who did not submit data to do so.
17.0	Patients and Caregivers	Data Access and Integration	PC-8	In your experience, what health data is readily available and valuable to patients or their caregivers or both?	● We posed this question to our partner patient advocacy organizations and report the following responses: ○ Large academic centers have improved portals where health records are fairly easily accessed but even these don't talk with other platforms labs, tests, etc. ○ After visit summaries. ● All data in the designated record set - whether digital or on paper - is valuable to patients and their

Ordinance	Section	Focus	Label	Question	Response
					caregivers and should be as readily accessible as possible. ● Although there is still friction for patients in getting access through portals, as explained in more detail in other sections of this response (see, for example, the resources linked in our response to Question PC-7.0, the data available through portals is a decent baseline, particularly for healthy patients. Lab test results, post-visit summaries, and medications prescribed are easier to obtain than they had been to the past, largely due to increased availability through portals.
18.0	Patients and Caregivers	Data Access and Integration	PC-8a	What data is valuable, but hard for patients and caregivers, or app developers and other technical vendors, to access for appropriate and valuable use (for example, claims data, clinical data, encounter notes, operative reports, appointment schedules, prices)?	● Patients still have difficulty getting access to data that should be easy to obtain - such as through portals or through requests directly to the provider - due to friction associated with all potential avenues of access. ● Patients still have a difficult - if not impossible - time getting full access to data generated by implantable devices. If these data are available at all, it is usually not complete and not integrated with other clinical information. ● Patients lack easily accessible mechanisms to provide patient-reported data to their providers, and when they do submit this data, they do not have access to a copy. ● Timely access to pricing data is still a challenge. Patients frequently do not know how much they will be charged in advance (they only sign paperwork acknowledging they could be balance billed), and

Ordinance	Section	Focus	Label	Question	Response
					when they are balance billed, those bills often show up months after the service was delivered, which creates further uncertainty as to whether the charges are legitimate. Providers should have a firm deadline of 30 calendar days to submit bills to patients.
19.0	Patients and Caregivers	Data Access and Integration	PC-8b	What are specific sources, other than claims and clinical data, that would be of highest value, and why?	● We posed this question to our partner patient advocacy organizations and report the following response: ○ Imaging data so clinicians and specialists can review the scans at different facilities rather than repeat it. ● Data from implantable devices and patient reported outcomes are two types of valuable data often not accessible to patients and caregivers.
20.0	Patients and Caregivers	Data Access and Integration	PC-8c	What specific opportunities and challenges exist to improve accessibility, interoperability and integration of clinical data from different sources to enable more meaningful clinical research and generation of actionable evidence?	● We posed this question to our partner patient advocacy organizations and report the following response: ○ In rare conditions, access to claims level data is still not widely and easily accessible and once accessed, grouping data into indication specific datasets when ICD10 codes are lacking remains highly problematic. CMS should pursue opportunities for creating better categorical data elements in EMRs for the rare genetic conditions and their corresponding gene. ● There is still too much friction associated with patients (or caregivers acting on their behalf) accessing data through portals (FHIR APIs in certified EMRs, for example). See the resources linked in our

Ordinance	Section	Focus	Label	Question	Response
					response to Question PC-2c of this RFI for more details. ● As set forth in our response to Question PC-10 below, TEFCA and national networks are not delivering data in response to patient requests, notwithstanding that patient access has always been a high priority of the 21st Century Cures Act (where TEFCA was established), and that the "patient access" use case is, at least on paper, a "required response" use case in both TEFCA and Carequality. ● Uncertainties about HIPAA still create obstacles to patient access from medical record offices and via national networks like TEFCA (see our response to Question PC 5b and Appendix A for more information). ● CMS and ASTP/ONC, along with OCR for HIPAA clarifications, should act promptly to use their authorities to address these unnecessary points of friction.
21.0	Patients and Caregivers	Data Access and Integration	PC-9	Given that the Blue Button 2.0 API only includes basic patient demographic, Medicare coverage, and claims data (Part A, B, D), what additional CMS data sources do developers view as most valuable for inclusion in the API to enable more useful digital products for patients and caretakers?	● Patients should have access to all care-relevant data possessed by CMS (arguably it all meets the definition of "designated record set" under HIPAA, which means CMS is obligated as a payor to make it available to patients upon request). ● At a minimum CMS could start by making the Data at the Point of Care, which is available to providers (at least as part of the pilot, although CMS has already committed to expand that to all providers), available to patients as well.

Ordinance	Section	Focus	Label	Question	Response
25.0	Patients and Caregivers	Data Access and Integration	PC-10	Is (TEFCATM) currently helping to advance patient access to health information in the real world?	● TEFCA is not yet helping to advance patient access to health information. There is so much potential to alleviate the burden patients and caregivers experience in trying to access their health information by providing them with a single onramp to information held by multiple dataholders – and yet the promise of this model for patients and their caregivers remains elusive.
26.0	Patients and Caregivers	Data Access and Integration	PC-10 a	Please provide specific examples.	● Under the Common Agreement, a participant or subparticipant data holder may decline to return records in response to an IAS request - even if the request generates a single patient match - if the participant/subparticipant's "local matching rules" have not been met. The rationale for this policy is that even with return of a single match in response to a query, there is no guarantee that the record is a 100% match - and participant/subparticipants perceive liability under HIPAA (or at least a requirement to notify) if there is a breach due to sending what turns out to be the wrong record. ● As noted in our response to Question PC-5b, the CARIN Alliance (of which we are a member) and other key interoperability stakeholders have asked OCR for further HIPAA guidance on this issue, but to date no action has been taken. ● Consequently, one influential QHIN is taking the position that response to individual access requests (IAS) through TEFCA should not include payload (actual records) but should instead be limited to a return of FHIR endpoints of locations for the patient's

Ordinance	Section	Focus	Label	Question	Response
					record; the patient would then need to connect to each FHIR endpoint in order to secure the payload. This inserts multiple steps in a process that should be seamless given other protections in place (required use of an approved IAL-2 credentialed service provider and submission of a token indicating that the patient has been successfully identity proofed at IAL & AAL 2). ● At the same time, at least one other certified electronic medical record provider, AthenaHealth, has demonstrated return of payload in response to a compliant IAS query. Here is a demonstration by b.well Connected Health of how this worked with an AthenaHealth customer: https://youtu.be/VLVYW0Ok2L4?feature=shared.
27.0	Patients and Caregivers	Data Access and Integration	PC-10 b	What changes would you suggest?	● CMS should use its authorities to incent or mandate the return of payload in response to an IAS query. ● To support this - and ease concerns of HIPAA provider data endpoints participating in TEFCA - HHS OCR should issue guidance regarding liability for return of a wrong record even when safeguards are followed.
28.0	Patients and Caregivers	Data Access and Integration	PC-10 c	What use cases could have a significant impact if implemented through TEFCA?	● IAS, public health, and what we refer to as patient-directed requests (i.e., when the patient requests for data to be pushed to a third party but it is not data intended for the patient to use/store/control).
32.0	Patients and Caregivers	Data Access and Integration	PC-10 g	Are there adequate alternatives outside of TEFCA for achieving widespread patient access to their health information?	● National networks have the greatest potential to give patients widespread access to most of their health information through a single query. Through all other mechanisms the patient needs to make

Ordinance	Section	Focus	Label	Question	Response
					multiple requests and/or sustain multiple connections.
33.0	Patients and Caregivers	Data Access and Integration	PC-11	How are health information exchanges (HIEs) currently helping to advance patient access to health information in the real world?	● A number of HIEs are now facilitating patient access to information, either directly or through a vendor. (See Selfiie for one of the vendors making this possible for HIEs who don't want to build their own connectivity mechanisms.)
34.0	Patients and Caregivers	Data Access and Integration	PC-11 a	How valuable, available, and accurate do you find the data they share to be?	● The data shared with patients through HIEs is the same data that HIEs share with their other customers (providers, health plans, public health departments), so it is as valuable to patients as it is to clinicians and payers.
35.0	Patients and Caregivers	Data Access and Integration	PC-11 b	What changes would you suggest?	● Most HIEs are not supporting patient access. Many believe they are not required to do so, as they are business associates under HIPAA and therefore rely on their business associate agreements for whether they can directly provide access to patients. These HIEs believe that the "infeasibility" exception in the Information Blocking Rules excuses their refusal to share data directly with patients. ● As noted in our response to Question PC-5b, getting more HIEs to participate in facilitating patient access will require OCR to establish regulations or guidance clarifying the intersection between Information Blocking Rule expectations and HIPAA rules for business associates.
37.0	Patients and Caregivers	Data Access and Integration	PC-11 d	What is the ongoing role of HIEs amidst other entities facilitating data exchange and broader frameworks for data	● Today, participation in national networks is voluntary - and HIEs and networks frequently struggle to find and sustain viable business models.

Ordinance	Section	Focus	Label	Question	Response
				exchange (for example, vendor health information networks, TEFCA, private exchange networks, etc.)?	● Consequently, for those HIEs of long duration, who have recognized value in their communities, it will be critical for these HIEs to continue to support a range of important use cases, including patient access. ● Finding a sustainable funding source for interoperability architecture and operations will be critical to gaining maximum value for improving population and individual health.
38.0	Patients and Caregivers	Data Access and Integration	PC-12	What are the most valuable operational health data use cases for patients and caregivers that, if addressed, would create more efficient care navigation or eliminate barriers to competition among providers or both?	● We posed this question to our partner patient advocacy organizations and report the following responses from two of them: ○ Finding the right provider for specific healthcare needs. ○ Binding cost estimates for pre-defined periods.
39.0	Patients and Caregivers	Data Access and Integration	PC-12 a	a. Examples may include the following:	
				(1) Binding cost estimates for pre-defined periods.	Yes, and there should also be requirements on providers for promptly billing patients after a service is rendered (no more than 30 calendar days).
				(5) Finding the right provider for specific healthcare needs.	This can be facilitated by patient-facing apps across multiple providers. Citizen Health is already facilitating the ability of patients to crowd source provider recommendations for specific health care conditions from other patients. We also are refining capabilities to match patients to published inclusion and exclusion criteria for clinical trials.

Ordinance	Section	Focus	Label	Question	Response
43.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-13	How can CMS encourage patients and caregivers to submit information blocking complaints to ASTP/ONC's Information Blocking Portal? What would be the impact? Would increasing reporting of complaints advance or negatively impact data exchange?	● Patients and caregivers are the group who submits the most Information Blocking complaints - but that doesn't mean that all patients and caregivers who face obstacles in obtaining their digital health information will submit a complaint. ● CMS should be sure that patients are guaranteed anonymity throughout the complaint process, even if complaints are pursued further through investigation. Patients fear backlash from their medical providers for submitting a complaint. Perhaps a trusted nonprofit can be a source of initial complaint gathering; in such a case the nonprofit can submit aggregate data (so no one patient's complaint is spotlighted) and potentially assure a focus on repeat offenders. ● Also, patients and caregivers have been submitting complaints to ASTP/ONC about information blocking since the regulations went into effect and no action has been taken on any of those complaints (or at least that is the perception). It is unlikely that patients and caregivers can be motivated to submit complaints (at the risk of potential backlash down the road) if no action is ever taken on any complaints.
44.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-14	Regarding digital identity credentials (for example, CLEAR, Login.gov, ID.me, other NIST 800-63-3 IAL2/AAL2 credentialing service providers (CSP)):	

Ordinance	Section	Focus	Label	Question	Response
45.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-14 a	What are the challenges today in getting patients/caregivers to sign up and use digital identity credentials?	● We posed this question to our partner patient advocacy organizations and report the following response: ○ Time and IT literacy. ● Although some identity proofing is necessary for triggering automated response to queries (given that most patients establish accounts with personal health applications in a strictly online encounter), the process is laden with friction, as it requires a patient to have technology with a decent camera, the capability to take good and clear pictures of a government-issued ID (assuming the patient has one), and the ability to take a selfie while moving one's head for "binding" the identification to the person. Digital natives understand how these capabilities work, but it can be challenging for older adults, persons with limited English proficiency, and others. Even for patients who regularly use digital tools in their daily lives, we have seen them experience inexplicable failures in the identity proofing process. ● As noted above, patients without a government issued ID cards will not be able to be identity-proofed remotely.
46.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-14 b	What could be the benefits to patients/caregivers if digital identity credentials were more widely used?	● If patients could easily and cheaply (ideally free) obtain a digital identity credential at a location they trust and frequent regularly (post offices, grocery stores, Walmart/Target, etc.), we would see more widespread use of digital identity credentials. States moving to mobile driver's licenses will also help,

Ordinance	Section	Focus	Label	Question	Response
					although it will take some time for mobile licenses to be ubiquitous). CMS should take care not to mandate the use of digital identity credentials until options for obtaining such credentials are easily and cheaply available.
47.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-14 c	What are the potential downsides?	● We will need some in-person, easily accessible alternatives to remove ID proofing to assure some patients are not left out of these opportunities.
48.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-14 d	How would encouraging the use of CSPs improve access to health information?	● CSPs are an important component of a digital identity ecosystem - however, people also have concerns about the ability of CSPs to use the data they collect for secondary purposes. ● Interoperability solutions should not depend on CSPs actually collecting and transmitting payload (health records). The role of the CSP (whether standalone or embedded in a multi-purpose product) should be to vet and verify identity.
49.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-14 e	What role should CMS/payers, providers, and app developers have in driving adoption?	● As noted above, patients should have opportunities to obtain digital credentials easily and through trusted organizations. Consider whether CMS could provide incentives for health care providers, including pharmacies, laboratories, and blood donation facilities, to perform identity proofing and provide a digital credential. ● Could CMS also leverage login-gov for Medicare beneficiaries as an identity solution? ● Could the IRS become a partner in driving adoption by allowing health care providers to also leverage a digital identity for filing tax returns and obtaining

Ordinance	Section	Focus	Label	Question	Response
					refunds for health care purposes? To make this solution effective would require safeguards to assure that fraudulent use of credentials for tax purposes could not carry over into health care (which may be an impossible task…).
50.0	Patients and Caregivers	Information Blocking and Digital Identity	PC-14 f	How can CMS encourage patients to get digital identity credentials?	● Could CMS provide incentives for Medicare and potentially Medicaid beneficiaries to obtain a digital credential? Requiring it for access to data is likely to have the opposite effect of reducing uptake of these tools unless a digital credential is free and locations for obtaining one are ubiquitous. ● Without guarantees that the identity cannot be used for law enforcement purposes, some populations are unlikely to ever take advantage of it.
54.0	Providers	Digital Health Apps	PR-1c	What responsibilities do providers have when recommending use of a digital product by a patient?	● In our experience, providers are largely reluctant to recommend digital products for their patients unless they have direct experience with the product or have done some digging into it. In other words, in general providers are careful with the advice to give to patients and shouldn't experience legal liability for bringing products that might help a patient to that patient's attention. ● At the same time, we have seen providers (and even more often, their electronic medical record vendors) go overboard in discouraging patients from using digital products, often on the basis of privacy concerns due to these products not being covered by HIPAA. ● Those privacy concerns are not fully misplaced - it is the case that most direct-to-consumer digital health

Ordinance	Section	Focus	Label	Question	Response
					tools are not covered by HIPAA, and only some are covered by state privacy laws. However, a number of patient-facing apps have responded to this lack of HIPAA coverage by adopting strong privacy commitments, commitments which are enforceable against them by the FTC. Citizen Health, for example, has attested to the CARIN Alliance Code of Conduct. Providers and their vendors often don't draw this distinction for patients. ● Although the information blocking rules provide a role for providers to educate patients about apps, and the CMS API rules require health plans under CMS' purview to do so, this education should be based on facts and not unduly alarmist (like a poison control label) or deliberately aimed at discouraging patients from using tools - even tools with strong privacy commitments - that could be helpful to them. ● Back in 2010, the multi-stakeholder Markle Foundation's Connecting for Health Initiative released a set of recommendations for providers and plans for deploying the Blue Button and other technical capabilities for patient access that included a simple disclaimer for patients, as follows: "If you download sensitive information to a shared or unsecured computer or device, others might see it. You are responsible for protecting the information you are downloading and for deciding with whom to share it. Are you sure you want to download a copy of your personal health information to the computer or device you are using? Yes/No/Tell Me More". This simple statement could be updated given the greater

Ordinance	Section	Focus	Label	Question	Response
					use of apps and platforms for downloading a patient's information to include that the information is not likely to be protected by HIPAA and the patient should read the privacy policy and terms of service to understand the app's policies with respect to the patient's data.
78.0	Providers	Data Exchange	PR-7	What strategies can CMS implement to support providers in making high-quality, timely, and comprehensive healthcare data available for interoperability in the digital product ecosystem? How can the burden of increasing data availability and sharing be mitigated for providers? Are there ways that workflows or metrics that providers are already motivated to optimize for that could be reused for, or combined with, efforts needed to support interoperability?	● The role that healthcare providers play in facilitating interoperability - from entering comprehensive data to support a wide range of health care needs, to securely maintaining that data and making it available to support those needs - is well documented. And yet we assume that the availability of certified technology (which some but not all providers use) will sufficiently help those providers easily fit into the role of "interoperability facilitator." Certified technology is helpful - but is far from sufficient. ● Even providers using good technology still need to operate, update, and consistently maintain that technology, and the tasks of doing so do not all fall to the technology vendor. ● CMS should use its payment authorities to assure that providers have a consistent source of funding to support interoperability activities.
94.0	Providers	Information Blocking	PR-12	Should ASTP/ONC consider removing or revising any of the information blocking exceptions or conditions within the exceptions (45 CFR part 171, subparts B through D) to	● The existing exceptions to the Information Blocking Rules are carefully crafted to protect actions that are taken to legitimately protect information, including at patient request. ● Rather than removing, revising, or expanding any exceptions, CMS should work closely with OIG to

Ordinance	Section	Focus	Label	Question	Response
				further the access, exchange, and use of electronic health information (EHI) and to promote market competition?	begin enforcing the rules by targeting common behaviors complained about by patients and caregivers and showing stakeholders that the federal government is serious about cracking down on Information Blocking. Given perceived lack of enforcement to date, it's unclear why any actor would be seriously concerned about risking an Information Blocking penalty.
95.0	Providers	Information Blocking	PR-13	For any category of healthcare provider (as defined in 42 U.S.C. 300jj(3)), without a current information blocking disincentive established by CMS, what would be the most effective disincentive for that category of provider?	● CMS should explore more robust use of its conditions of participation as a disincentive for information blocking by providers. Already the bar for violating the rules is a high one, as CMS must show that the providers knew their action, or failure to act, was unreasonably blocking information. This argues for a serious penalty for a provider found to be in violation.
96.0	Providers	Information Blocking	PR-14	How can CMS encourage providers to submit information blocking complaints to ASTP/ONC's Information Blocking Portal? What would be the impact? Would it advance or negatively impact data exchange?	● See our comments in response to Question PC-13 above, which is even more applicable here. Providers fear retaliation from peers and from vendors for submitting information blocking complaints. ● As recommended by the CARIN Alliance, CMS should facilitate the submission of bulk, anonymous Information Blocking complaints to an intermediary, who can then report them to ONC and/or CMS, to preserve anonymity of complainants and surface to the top the most serious cases, in particular repeat offenders. ● It is also critical for all stakeholders to see enforcement happening, so that providers think

Ordinance	Section	Focus	Label	Question	Response
					there is some value to engaging in the complaint process.
97.0	Payers	Payers	PA-1	What policy or technical limitations do you see in TEFCA? What changes would you suggest to address those limitations? To what degree do you expect these limitations to hinder participation in TEFCA?	● The ability of entities to de-identify and monetize the data they receive through network exchange could be an obstacle to network participation. Much of the monetization that occurs happens without patient consent or knowledge, or any of the value from these transactions going for the benefit of the patient. (As noted above in our response to Question PC-5a, Citizen Health does license de-identified data to commercial researchers - but only with the consent of the patient, and in that case the patient gets a share of the fee.) ● It would be impossible to impose a limit on de-identification of data received through network queries, as it makes no sense to require providers (or any other participant/subparticipant) to separately store data received through the network from data that originates in their records. ● Policymakers could consider addressing this issue by eliminating the concept of de-identification (i.e., removing any PHI from at least some HIPAA protections), given the possibilities of re-identifying even HIPAA-de-identified data. ● Another possible way to address this to at least prohibit intermediaries from caching and monetizing data, since participants and subparticipants do not choose all of the vendors who might cache their data as part of processing a network query (e.g., Citizen Health chooses its QHIN to process individual access

Ordinance	Section	Focus	Label	Question	Response
					queries, and we chose a QHIN that does not monetize the our patient's records, but we can't control the QHINs through which the data I requested on behalf of my patients will flow and who may cache and monetize that data, even though our patient user never consented to such activity). ● Other possibilities (not mutually exclusive) could include requirements for transparency about uses and disclosures of de-identified data, and potentially requiring patient consent or at least an opt-out for certain types of de-identified data transactions (for example, those with limited value to patients).
111.0	Technology Vendors, Data Providers, and Networks	Digital Identity	TD-3	Regarding digital identity implementation:	
112.0	Technology Vendors, Data Providers, and Networks	Digital Identity	TD-3a	a. What are the challenges and benefits?	● See our response to Question PC-14a for details on the challenges.
117.0	Technology Vendors, Data Providers, and Networks	Technical Standards and Certification	TD-6	What unique interoperability functions does TEFCA perform?	● The greatest potential of TEFCA is eliminating "portalitis" - the need for patients to establish and maintain multiple connections in order to try to compile a complete record of their health care.
120.0	Technology Vendors, Data	Technical Standards	TD-7	To what degree has USCDI improved interoperability and	● As noted above in our response to Question PC-2c, we applaud the work of HHS to expand USCDI. But for data that is not resident in an EMR (such as

Ordinance	Section	Focus	Label	Question	Response
	Providers, and Networks	and Certification		exchange and what are its limitations?	images), it may be impossible to think we can facilitate interoperability of all data through APIs in electronic medical records. ● Further, given the challenges we have had over the years in getting vendors of certified technology to open up the pipes and make that data accessible to others, including technology that might compete with them, **we should consider carefully whether it is wise to vest all of our interoperability efforts in expanding the sharing capabilities of their technology.** We may need them to act more like public data utilities - but these vendors have shown some reluctance to being turned into such vehicles.
121.0	Technology Vendors, Data Providers, and Networks	Technical Standards and Certification	TD-7a	Does it contain the full extent of data elements you need?	● As noted in our response to Question PC-2c, USCDI is missing all of the data elements of the designated record set, and it may not be technologically possible (or advisable) for us to overrely on these pipes.
123.0	Technology Vendors, Data Providers, and Networks	Technical Standards and Certification	TD-7c	If so, would adding more data elements to USCDI add value or create scoping challenges? How could such challenges be addressed?	● See our response to Question PC-2c.
124.0	Technology Vendors, Data Providers, and Networks	Technical Standards and Certification	TD-7d	Given improvements in language models, would you prefer a non-proprietary but less structured format that might improve data coverage even if it requires more processing by the receiver?	● Technology vendors have the capability to process unstructured data, and having it available in unstructured format is always preferable to waiting for access until that data is more structured.

Ordinance	Section	Focus	Label	Question	Response
151.0	Technology Vendors, Data Providers, and Networks	Data Exchange	TD-17	Given operational costs, what role should CMS or ASTP/ONC or both have in ensuring viability of healthcare data sharing networks, including enough supply and demand, that results in usage and outcomes?	● Steady funding sources and enforcement of data governance expectations are critical roles for the federal government to play. OCR also can play a role in the latter through HIPAA policy and enforcement.
152.0	Technology Vendors, Data Providers, and Networks	Compliance	TD-18	Information blocking:	
153.0	Technology Vendors, Data Providers, and Networks	Compliance	TD-18 a	Could you, as a technology vendor, provide examples for the types of practices you have experienced that may constitute information blocking. Please include both situations of non-responsiveness as well as situations that may cause a failure or unusable response?	● In Citizen Health's early days, we measured and publicly reported on the response of providers to medical record access requests we submitted on behalf of the patients using our platform. This was measuring more HIPAA compliance, since at that time we were sourcing records solely by submitting medical record requests directly to providers (vs. working through portals, APIs, or networks). Although we no longer maintain the Patient Record Scorecard, here is an early example of our work - https://www.medrxiv.org/content/10.1101/19004291v1. ● We also shared some of these obstacles -which still need to be addressed, given that portals and networks do not produce a complete record for patients - in our comments to the OCR proposed

Ordinance	Section	Focus	Label	Question	Response
					rulemaking in 2021 (see our response to Question PC-5b and Appendix A for relevant provisions). ● Please also see our linked resources in our response to Question PC-2c.
154.0	Technology Vendors, Data Providers, and Networks	Compliance	TD-18 b	What additional policies could ASTP/ONC and CMS implement to further discourage healthcare providers from engaging in information blocking practices?	● As noted multiple times above, enforcement of the existing Information Blocking Rules is key. ● We also agree with b.well Connected Health that the ONC certification program should focus on certifying APIs.
155.0	Technology Vendors, Data Providers, and Networks	Compliance	TD-18 c	Are there specific categories of healthcare actors covered under the definition of information blocking in section 3022(a)(1) of the Public Health Service Act (PHSA) that lack information blocking disincentives?	● The CMS enforcement rule for providers covers only providers under value-based incentives, which means fee-for-service providers lack any mechanism for penalty under the information blocking rules. In addition to creating an enormous gap in enforcement for patients seeking their data, it is also unfair to providers, as it subjects only some of them to penalties for blocking.

Appendix A

Relevant Excerpts from Ciitizen (now Citizen Health's) HIPAA Proposed Rule Comments

May 4, 2021

Robinsue Frohboese
Acting Director, Office for Civil Rights
U.S. Department of Health and Human Services
Office of the Secretary
RE: RIN 0945-AA00

Submitted electronically at http://www.regulations.gov

Dear Acting Director Frohboese:

On behalf of Ciitizen, I appreciate the opportunity to provide public comments on the proposed rule entitled *Proposed Modifications to the HIPAA Privacy Rule to Support, and Remove Barriers to, Coordinated Care and Individual Engagement (RIN 0945-AA00).*

Ciitizen's mission is to empower the world's 7 billion citizens to have complete control of their health data: to share it with whomever, whenever, and wherever they want. With a particular focus on empowering sick patients, the Ciitizen online platform democratizes health care by putting copies of health information in the hands of patients - the stakeholders most motivated to collect it, use it, and share it liberally to save their own lives and the lives of others just like them.

Ciitizen helps patients leverage their right of individual access under the HIPAA Privacy Rule to have copies of all protected health information (PHI) in a designated record set gathered for them in one place. Ciitizen is initially focusing on very sick patients – beginning with cancer and recently expanding to rare neurological conditions and other diseases – who need their complete health histories in order to participate more fully in their care, to obtain second opinions and pursue other treatment options, and to contribute their data to power medical research. Ciitizen users need more information than is currently available to them through

health care provider or health plan portals or application programming interfaces (APIs). As a result, Ciitizen obtains records for its users the "old-fashioned way" – by submitting record requests on behalf of its users to medical records and radiology/imaging departments or staff at health care providers and plans and having those records sent to Ciitizen for population in the user's account.

Many of the challenges we have faced in helping our users obtain their medical records are due to some health care providers, or release-of-information vendors working on their behalf, treating Ciitizen as a "third party" seeking PHI instead of as a service that individuals engage to collect, organize, store, and manage their health information on their behalf, pursuant to their preferences. These challenges were exacerbated by the court's decision in *Ciox Health LLC v. Azar* (hereinafter, *Ciox v. Azar*). We greatly appreciate and support OCR's efforts in the proposed rule to draw a clear distinction between services like Ciitizen, which stand in the shoes of the individual, and services where the individual right of access is a mere conduit for data to benefit a third party. We also greatly appreciate and support, in the wake of the *Ciox v. Azar* decision, OCR's efforts to further flesh out the right of access regulatory provisions versus relying more on informal guidance to apply those regulations to common scenarios. Our comments (summarized below) are intended to enhance OCR's efforts to improve the ability for individuals to obtain access to, or copies of, their PHI:

- OCR's proposal to require business associates to respond to individual access requests only when directed to do so by their business associate agreement ignores provisions in the 21st Century Cures Act that require certain business associates to refrain from "blocking" information, including in response to individual requests. We urge OCR to revise the proposed rule to fully implement the clear intent of Congress in the Cures Act that "actors" (such as health information exchanges and networks (HIEs) and certified electronic health record (EHR) vendors) not use contractual provisions to block requests for electronic health information (EHI), particularly from individuals or apps or services acting on their behalf.

- We urge OCR to further clarify the definition of "personal health application," or use the term "personal health record," to expand the types of tools and services individuals can engage to obtain, manage, and store their health information beyond just "apps" and to enable covered entities, and business associates working on their behalf, to accurately distinguish between personal health records engaged by individuals and tools or services primarily intended for the benefit of third parties.

- We urge OCR to maintain an expansive definition of “electronic health record,” (EHR) consistent with the definition in the Health Information Technology for Economic and Clinical Health Act of 2009 (HITECH) and align the right of individuals to have information from an EHR sent directly to the third party of their choice with the existing HIPAA right of access and ONC’s Information Blocking regulations.

- We support the proposed changes in the right of access regulations giving individuals the right to inspect their PHI, including to take notes, videos, recordings, and photographs, using personal resources.

- We support proposals shortening the amount of time entities have to respond to an individual’s request for access to “as soon as practicable, and no later than 15 days” in most cases. We also support conditioning extensions of this deadline on entities implementing policies to assure faster delivery of copies when needed (such as for urgent treatment-related purposes or to meet a benefits application deadline).

- We support the express prohibition on unreasonable measures for individuals seeking access to or copies of their records, and we urge OCR to further clarify what constitutes unreasonable identity proofing requirements. We further urge OCR to add additional examples of unreasonable measures to the regulation, including refusal to accept electronic signatures, refusal to accept requests for access by e-mail, and requirements to complete an entity’s particular request form, even if that form is short.

- We support the proposed provisions regarding permissible fees charged for access to PHI – and the proposed requirement to publicly post those fees - but urge OCR to: be clearer in the Privacy Rule regarding the application of state law fees to the individual right of access, clarify what is intended by an “internet-based method,” and publish more guidance on which fees are permissible in particular circumstances.

- We question the policy rationale behind the proposal to require entities to accept oral requests from individuals when they are seeking to direct that information in an EHR be sent directly to a third party (including another health care provider or health plan) given the potential for abuse by someone claiming to be acting on behalf of the individual. However, we support that entities should be required to accept an oral request from an individual seeking to

inspect/videotape/record/photograph their PHI during an office visit or hospital stay, as there is no doubt regarding the origin and legitimacy of that request.

- We support OCR's proposal to consider provider queries to HIEs to fulfill an individual right of access request to count as "customer service" under "health care operations." We further urge OCR to consider making such HIE queries in response to individual access requests mandatory.

- We do not believe that covered entities (or business associates operating on their behalf) should be required to warn individuals about potential privacy risks associated with sharing their health information with a personal health application/record or third party not covered by HIPAA; however, if such warnings are voluntarily provided, we urge OCR to prohibit long and overly complicated warnings that could serve as an unreasonable measure to facilitating individual access to their health information via the tool or service of their choice.

Our detailed comments on these provisions are set forth below.

Recognizing the Role of Certain Business Associates as "Actors" under the Information Blocking Rules (45 CFR 164.502(a)(4)(ii))

Historically OCR has taken the position in guidance that whether business associates (BAs) are required to respond directly to individuals seeking access to their PHI depends on the terms of their business associate agreements (BAAs). In the proposed rule, OCR inserts this guidance into the Privacy Rule. However, this proposal runs counter to the Cures Act and ONC's Information Blocking rules, at least for entities covered by those rules. Overall, OCR needs to take further action to assure the Privacy Rule is consistent with these new federal laws.

The Cures Act establishes penalties for "information blocking" by health care providers, certified EHR vendors, and HIEs (hereinafter, "actors"). Information blocking is defined as a practice that, except as specified by the HHS Secretary in regulations, "is likely to interfere with, prevent, or materially discourage access, exchange, or use of electronic health information." (42 USC 300jj-52(a)(1)(A)) The statute provides a list of non-exclusive examples of information blocking, including "practices that restrict authorized access,

exchange, or use under applicable State or Federal law of such information for treatment *and other permissible purposes under such applicable law*…." (42 USC 300jj-52(a)(2)(A) emphasis added)

In the Information Blocking rules (and guidance accompanying those rules), ONC correctly recognizes that contracts can be vehicles used by actors to interfere with the sharing of EHI, to assure that actors do not attempt an end-run around Cures through contractual provisions. Unfortunately, existing provisions of the HIPAA Privacy Rule run counter to the Cures Act and Information Blocking rules, as applied to actors. Pursuant to the Privacy Rule, BAAs are required to include provisions establishing the BA's permitted uses and disclosures of the PHI covered by the agreement. (45 CFR 164.504(e)(2)) Historically these BAAs have been used to limit how a BA can use and disclose PHI, sometimes legitimately to protect individual privacy but more frequently to protect a covered entity's business interests.[1] And covered entities could count on OCR to enforce these limitations, as BAs are not permitted to violate the terms of their BAAs. (45 CFR 164.502(a)(3)) However, instead of addressing this conflict, OCR exacerbates the problem – not only by failing to address the Cures Act and Information Blocking rules through amendments to the BA provisions of the Privacy Rule but by proposing a regulatory change that cements the BAA as arbiter of whether a BA discloses information to individuals. This provides actors with legal cover for declining to share data with individuals who request copies of their electronic health information.

Essentially, the Cures Act and the Information Blocking rules establish a new governance regime for electronic health information held by actors, and the Privacy Rule must be modified to recognize this reality. The HIPAA Privacy Rule still constitutes the outer boundary of what uses and disclosures of EHI are permitted, providing important guardrails to protect patient privacy. But the Privacy Rule should not expressly require or invite entities to place further limitations on the sharing of this information, limitations which would then be enforceable by OCR. Although the Information Blocking rules have their own enforcement and penalties, it is highly unlikely that penalties will be imposed by one branch of HHS for activities or behavior that is expressly endorsed by another branch. This type of conflict is a result HHS was expressly directed by Congress to avoid. (See 42 USC 300jj-52(b)(3) & (d)(4))

Of particular concern to Ciitizen is allowing covered entities and BAs, through voluntarily entered contractual provisions in a BAA, to limit the mechanisms through which individuals can access EHI from actors. <u>The Cures Act expressly prioritizes actors sharing electronic health information with patients</u>. For example, Section 4006(a) of the Cures Act envisions that certified EHR vendors and

health information networks or exchanges would provide patients with health information held by these networks and *requires* OCR to set forth guidance on this topic.[2] OCR has yet to provide this guidance; instead, the proposal to reinforce the BAA as controlling whether any BA can disclose information to individuals conflicts with what Congress specifically directed with respect to actors and electronic health information.

Further, disclosures to individuals upon request is a required disclosure under the Privacy Rule, with limited exceptions. The text of the existing Privacy Rule already establishes that there is no HIPAA violation when a BA discloses PHI where required by law to do so - and the Cures Act establishes a separate legal obligation for actors to refrain from blocking the sharing of EHI, including with individuals upon request, absent application of an Information Blocking rules exception. For example, the HIPAA Privacy Rule provides that BAs may use or disclose PHI (of which EHI is a subset) only as permitted by their BAA "or as required by law." (45 CFR 164.502(a)(3)). The Privacy Rule also expressly requires BAs to make data available to individuals. For example, the Rule states that BAAs must include provisions requiring the BA to "make PHI available in accordance with" the HIPAA individual right of access provisions (45 CFR 164.504(e)(2)), and BAs are required to disclose PHI "to a covered entity, *the individual or the individual's designee.*" (45 CFR 164.502(a)(4)(ii) (emphasis added)) Although in preexisting guidance OCR has urged covered entities and BAs to establish in the BAA which entity is responsible for responding to an individual's right of access request,[3] the regulations clearly obligate BAs to make PHI available to individuals and envision that this information could be provided directly. Consequently, the proposed regulatory change in Section 164.502(a)(4)(ii) arguably takes a step backward from the Privacy Rule's existing text, when read in combination with the new obligations under the Cures Act. Given the emphasis in Cures on patient access, coupled with text in the Privacy Rule that mandates disclosures to individuals in most cases and provides that BAs can make these disclosures directly, it makes little sense for OCR to propose an amendment to the Rule that goes in the opposite direction and could block individuals from accessing their information from actors.

Finally, Section 4006(b) of the Cures Act specifically allows (but does not require) "business associates" to respond directly to individual access requests for PHI. This is a separate subpart of the Cures Act, which does not expressly override or supersede Sections 4004 (the Information Blocking provisions) and 4006(a) (expressly referencing patient access to PHI from actors). A logical reading of all of these Cures Act provisions together yields a conclusion that Congress intended that actors (some of which also are BAs) be directly accountable to responding to requests for EHI, particularly from individuals, and intended for BAs that are not actors to have the authority to respond to individuals. (Of note: OCR also should consider whether allowing a BAA to preclude any BA from

responding directly to an individual access request conflicts with Section 4006(b), where Congress expressly authorizes BAs to take such actions.)

To the extent that some BAs face challenges in providing individuals – or their apps – with access to PHI, actors covered by the Information Blocking rules can look to leverage one of the eight safe harbors or document why declining to provide such access does not constitute information blocking. OCR should refrain from providing actors with a built-in excuse in the form of a contrary BAA provision.

Allowing the BAA to dictate whether actors subject to the Information Blocking rules are permitted to disclose EHI will significantly undermine the impact of the Cures Act and fails to account for what is often a significant power imbalance in the covered entity/BA relationship. The Privacy Rule presumes that the covered entity dictates the terms under which a BA can use and disclose PHI, with the BAA serving the CEs' needs within the outer boundaries of the Privacy Rule. But in many cases, the BA is the one to dictate the terms of the relationship – either because that BA has more economic power or is otherwise in a position to set the terms of the relationship (for example, an HIE that seeks to have all of its provider members sign the same BAA, or a certified EHR vendor setting the same BAA terms for all of its provider customers). If the BAA is the determining factor for whether a BA– even one covered as an actor by the Information Blocking rules - is required to share EHI with an individual, it creates a significant end run around the Cures Act. This is because it provides entities covered by the Information Blocking rules with an easy vehicle for significantly limiting the purposes for which they will share information with individuals or other requestors, notwithstanding the clear intent of the Cures Act and the Information Blocking rules to facilitate broader data sharing for permitted purposes than what occurs today. We are already seeing examples of this, with HIEs declining to share with individuals due to BAA terms. Because the BAA can be – and often is - used to significantly curtail how a BA can share EHI, Congress could not have intended for OCR to implement the Cures Act by allowing a contractual vehicle to create obstacles to sharing of EHI otherwise permitted by law. We urge OCR to work with ONC to assure that the HIPAA rules fully implement the Cures Act and are in sync with Information Blocking provisions.

From a timing perspective, waiting for clarity on these provisions until OCR issues its final rule will significantly delay full implementation of the Cures Act and Information Blocking rules. OCR has issued helpful guidance to facilitate the sharing of PHI related to fighting or managing COVID-19. Many actors under the Information Blocking rules (for example, HIEs and certified EHR vendors) are playing key roles in facilitating the sharing of EHI related to COVID-19. For example, individuals would benefit

tremendously from being able to access COVID-19 testing and vaccine information directly from HIEs and certified EHR vendors, particularly as employers and places of public gathering are increasingly requiring (or leaning toward requiring) proof of vaccine status. Clarifying that:

1) actors cannot use or rely on BAAs to block requests for information from individuals and
2) actors can be assured that they can share such information with individuals notwithstanding their BAAs

will be critical to assuring that individuals can obtain the necessary information to prove COVID-19 negative or vaccination status. We urge OCR to issue preliminary guidance promptly in advance of finalizing this rulemaking.

Clarification of Individuals' Right to Have Information Sent to a "Personal Health Application" (45 CFR 164.501 & 164.524(b)(3) & page 6468 question (k))

Ciitizen strongly supports OCR's proposal to include, within the right of access provisions, the right of an individual to receive PHI in the form and format requested by the individual and interpreting "form and format" to include when individuals want to have information sent to a personal health tool – identified in the proposed rule as a "personal health application." We applaud the key elements of a "personal health application" - chiefly that it "can be drawn from multiple sources" and is "managed, shared, and controlled by or primarily for the individual and not primarily for a covered entity or another party." However, we have concerns about the decision to use the term "personal health application" versus relying on the original term in HITECH, "personal health record"[4]. Not all tools or services selected by individuals to manage and store their PHI will necessarily be apps, at least as that term is generally understood. For example, Ciitizen is not a mobile app; we are an online platform accessible by individuals via any web browser either on a phone or via computer. Many online tools and services will meet the essential prongs of the proposed "personal health application" definition but will not technically be an "app" accessible from an "app store" hosted by a mobile phone service provider. To maximize individual choice with respect to the service or tool they choose to store their health information, and to avoid locking in today's technologies, we suggest that OCR use the more functional definition of "personal health record" from HITECH or at a minimum define "personal health application" so that it covers more tools than those that today are commonly recognized as apps.

It is also critical that OCR not limit this definition to only those tools or services that obtain PHI for individuals via connection to a standards-based API in a covered entity EHR. Today (and for several years into the future), individuals are not able to obtain the entirety of their PHI in a designated record set through standards-based APIs, so it is essential that OCR recognize tools and services that help individuals obtain their health information through other mechanisms. Although the proposed regulatory definition does not contain this limitation, the use of the term "application" and some of the language of the preamble open the door to HIPAA-covered entities adopting a narrower definition. OCR should be clear that covered entities (and BAs) should honor an individual's form and format request as long as the tool or service being used by the individual meets the core elements of the definition and delivering the copy to the tool or service is "readily producible" by the covered entity or BA.

In the preamble OCR states that a "personal health application," based on the proposed definition of that term, would not be covered by the HIPAA Rules. However, OCR should consider the possibility that an individual could choose to use an app offered by a particular covered entity and seek to have other providers or plans send data to populate that app. We suggest OCR may want to be clear that the definition does not preclude an individual's right to have PHI sent to an app offered by a covered entity, as long as that app otherwise meets the essential prongs of the definition. It is doubtful that a covered entity would decline to send PHI held by that covered entity to that covered entity's consumer app - but other covered entities may decline to do so if an app that is covered by HIPAA cannot meet the definition of "personal health application."[5]

The preamble also states that individuals (or their personal health representatives) use a personal health application "for the individuals' own purposes, such as to monitor their own health status and access their own PHI." (page 6457) We have concerns that the use the phrase "for the individuals' own purposes," coupled with the limited examples, could be interpreted to limit the definition to tools or services that are for personal use only. Individuals should be able to use information in a personal health application or personal health record for any purpose that suits them, including sharing it with others to get treatment recommendations, sharing it with friends and family members to keep them abreast of what's going on with their health, sharing it with social networks, sharing it with a health plan as part of a wellness program, or contributing it to research. As long as the personal health application or record is "managed, shared, and controlled by or primarily for the individual and not primarily for a covered entity or another party," that app, tool, platform, or service should meet the definition versus imposing additional constraints that the information only be for the individuals' "personal" use. We urge OCR to provide further clarification when finalizing this definition.

It is critical that the definition of “personal health application” or “personal health record” be sufficiently clear as to apply only in circumstances where the tool or service has been engaged by the individual, to further distinguish this pathway for individual access from circumstances where third parties offer apps or tools in order to seek to access PHI largely for their own benefit. The failure to clarify this definition in a way that minimizes abuse by third parties seeking data primarily for their own business purposes is critical to enabling individuals to use personal health tools seamlessly to obtain, manage, and control their health information. Today, Ciitizen is often treated like a third party and not as a tool engaged by the individual, notwithstanding that our policies clearly provide individuals with the ability to manage, share, and control their health information. When we are treated as a third party, high fees are often levied for information access. To avoid passing that high fee on to the patient, the patient has to play middleman: first she must request that her records be sent to her and then she has to make the effort to forward the information to us in order for that information to be populated in her Ciitizen account. Individuals shouldn’t have to work that hard just to get their health records into tools or services they have chosen.

OCR further asks what types of activities should be encompassed in the terms, “managed,” “shared,” and “controlled” in the proposed definition of personal health application/record. Activities that might be considered to be part of an individual managing, sharing, or controlling his/her personal health application/record should include whether the individual (or a personal representative): has a choice of whether or not to open an account with the personal health application/record; has unfettered access to their information in the account; determines with whom the information can be shared and under what circumstances; has the capability to use (or to facilitate use) of the information in the record for health, wellness, and other personal purposes; and has the capability to shut down the account and take the information with them or have it deleted.

Definition of “Electronic Health Record” (45 CFR 164.501, page 6468 questions (a)-(h))

In light of the federal district court decision in *Ciox v. Azar*, OCR has proposed new regulations to replace those established in the Omnibus Rule implementing the HITECH provision giving individuals the right to have “health-related information” on an individual from an “electronic health record” sent directly to the third party of their choice. OCR proposes to further refine the definition of “electronic health record” set forth in HITECH by stating that it includes, “*but is not limited to*” providers that have a “direct treatment relationship” with individuals, and to clarify that “health-related information” means the same as the HIPAA-defined term

"individually identifiable health information." (45 CFR 164.501) OCR states in the preamble that "the Department does not propose to include covered health care providers who have indirect treatment relationships with individuals." (page 6456) OCR further states in the preamble that the definition "would not include health-related electronic records of covered health care providers that only supply durable medical equipment to other providers." (Id.). OCR also questions whether electronic health records held by health plans should meet the definition. (page 6462)

HITECH provides a workable definition of "electronic health record" – a digital health record that is "created, gathered, managed, and consulted by authorized health care clinicians and staff." [6] OCR does not provide a policy rationale for its further narrowing of this definition. The right of individuals to access their PHI in a designated record set applies to all covered entities, not just those with direct treatment relationships, and includes both providers and payers. In the context of an individual exercising their right of access to have information sent directly to a third party versus the individual having to first get the record herself before sending it to the third party of her choice, what is the policy rationale for narrowing the definition instead of giving it the broadest possible interpretation?

OCR may be justifying the exclusion of indirect treatment providers on the assumption that these providers furnish all the health information that they generate to the direct treatment provider, so individuals may readily access all their information through the direct treatment provider. However, this assumption is not always accurate. For example, individuals may want a copy of an MRI or an x-ray. In our experience at Ciitizen, the fastest way – and sometimes the only way – to obtain copies of images is directly from the radiologist (in addition, imaging centers are often separate from the health care facilities of the ordering providers). The situation may be worse with respect to providers who furnish and monitor durable medical equipment (DME) such as heart monitors. The DME provider may have full electronic records of the data recorded by the monitors, while the referring provider may be sent only summary information or alerts when monitors are malfunctioning. As a result, if the individual can only direct their health information from the direct treatment provider, the individual could only have a
partial record sent to the third party of their choice. Consistent with the breadth of the right of access as augmented by HITECH (as well as the court's opinion in *Ciox v. Azar*), we urge OCR to interpret "electronic health record" as including the electronic records consulted not only by direct treatment providers but also by providers who have indirect treatment relationships with individuals.

In the Omnibus Rule, OCR relied on this HITECH provision (as well as the original HIPAA statute) to initially provide individuals with the broad right to have their health information sent to third parties of their choice, which suggests the need to broadly interpret the "electronic health record" definition so that it matches the scope of HIPAA right of access as closely as possible. In this proposed rule, OCR has established another pathway for individuals seeking to send information (regardless of whether or not it comes from an "electronic health record") to personal health records/applications engaged by the individual, but given the *Ciox v. Azar* opinion, some may question whether there is sufficient statutory authority for this regulatory change.[7] As a result, we believe it makes sense for OCR to interpret the definition of "electronic health record" broadly, in order to more closely match the individual right of access. We also urge OCR to clarify that the information that an individual can direct to a third party is limited to information in a designated record set, consistent with the overall HIPAA right of access. We also urge adoption of other provisions (for example, requiring that requests be submitted in writing – see below) designed to reduce the potential for third party abuse.

Support for the Right to Inspect (45 CFR 164.524(a))

We support the proposed changes in the right of access regulations giving individuals (and their personal representatives) the right to inspect their PHI, including to take notes, videos, recordings, and photographs, using personal resources. This should be permitted at the point of care whenever such access would not genuinely risk possible exposure of another individual's PHI (and OCR should make clear that such point-of-care access should be provided promptly and not just "within 15 days" (see further comment below on the proposed changes to the timing of providing individuals with access to their PHI). An oral request should be more than sufficient for a point of care request, and entities should be required to accept such oral requests (versus being merely permitted to do so). OCR asks in the preamble if there are circumstances when a covered entity (or BA acting on its behalf) would be allowed to provide copies in lieu of inspection. Ciitizen is hard pressed to think of such a circumstance – but if such circumstances exist, providers should not be permitted to charge fees for the copies, since the individual requested inspection, for which fees would not be permitted.

Timeliness of Response to Individual Requests (45 CFR 164.524(b)(2)(i) and page 6468 question (n), page 6469 questions (r) & (s))

Ciitizen is pleased to see the proposal to adjust the deadline for entities to respond to HIPAA right of access requests from 30-60 days to 15-30 days. On average, Ciitizen users (with our assistance) are able to obtain their records in two weeks on average – but too often entities take almost the full 30 days or beyond to produce records for users. We also support the proposal to allow entities to

take beyond 15 days IF they have a policy in place (and that policy is in effect) whereby individuals needing their health information more quickly than 15 days (such as for second opinions to treat a serious illness or to try to meet eligibility requirements for a clinical trial, or to meet a benefits application deadline) can have those requests processed more quickly. We recognize that such a provision might require individuals to specify the purpose of their requests, but we think it makes sense that individuals seeking information for an urgent purpose would need to at least generally indicate that purpose in order to justify prioritizing that request over others in the queue, as long as the default for most requests is that individuals are not required to indicate any particular purpose. We also support OCR's policy position that time spent by the entity in clarifying an individual's request does not stop the clock regarding meeting the 15-day maximum.

Although we understand OCR's desire to maintain a medium-neutral Privacy Rule (to the extent possible), a 15 day timeframe is much more time than should be needed to produce records held electronically (hybrid – combination of paper and digital – requests may take longer, at least for the paper portion). The adoption of even a 15-day expected turnaround time for all PHI puts the Privacy Rule well behind expectations set by the Information Blocking and Interoperability Rules (from ONC, and with respect to the latter, from CMS), at least with respect to EHI. We also believe requests for inspection – particularly when an individual seeks to examine, or even take photos of or record, their PHI while at an office visit or while hospitalized – should be processed far more quickly than 15 days. We strongly support that OCR has worded the proposed regulation so that it requires entities to respond to individual access requests "as soon as practicable, *but no later than* 15 days" (emphasis added) (again, with the possibility of extension – largely intended for paper records – if the entity has a policy in place that facilitates expediting individual requests). This regulatory language should be interpreted to create an expectation that an entity will respond much sooner than 15 days when it is "practicable" for them to do so, similar to OCR's expectations regarding notification of individuals in the event of a breach of PHI. If this is what OCR intended, and that OCR could enforce a failure of an entity to respond within 15 days when it clearly was practicable for them to do so, we urge OCR to make it much clearer (either in the preamble or in the regulations or both) so that the new 15-day standard does not become the default for all requests.

Prohibiting Unreasonable Measures for Individuals Seeking Records (45 CFR 164.524(b)(1)(ii) & 164.514(b)(2)(v), and page 6470 question (ii))

We strongly support OCR's proposal to expressly prohibit entities from imposing unreasonable measures for individual access. These measures are typically imposed out of convenience to the entity and, to some degree, to give the entity greater assurance that the individual requesting the information is authorized to receive it. But regardless of the benign intent of these measures, they often impose significant obstacles to individuals seeking to access their health information or on personal representatives seeking to access information of a loved one.

In sourcing records for our users, we have found the following to be among the biggest obstacles:

- Entities requiring individuals to come "in person" to obtain records (guidance currently addresses this).
- Entities requiring individuals to submit requests either by mail or by fax (guidance currently allows; mail delays entity receipt of requests, and many individuals don't have access to fax machines).

- Entities not accepting a "digital" signature, making it challenging for individuals to submit remote requests.
- Entities requiring individuals to use the entity's particular request form, which can be a burden even when that form is short and is not the lengthier HIPAA-compliant authorization.
- Entities imposing high fees for copies (see separate section below regarding fees).
- Entities requiring that requests be submitted and processed through a portal or API.
- Entities requiring that signatures be notarized, particularly when the requester is a personal representative.
- Entities imposing unreasonable verification requirements (in our experience, this occurs mostly through the refusal to accept digital signatures).
- Entities refusing to e-mail records to individuals, even after individuals accept the security risks of unsecure email transmission.

The proposed rule expressly includes a “non-exhaustive” list of unreasonable measures. We support this proposal, although we do wonder whether – notwithstanding the labeling of the list as “nonexhaustive” – it will be difficult to have other measures that are not expressly listed still be considered to be unreasonable. Nevertheless, we agree with the approach of providing more clarity in the regulations themselves, since regulations are a stronger source of authority, and entities are frequently less aware of guidance, which tends to be created episodically and therefore exists in multiple places.

We support that OCR has included several of the obstacles identified above in the list of obstacles that are determined to be “unreasonable” – including requiring individuals to come in person, prohibiting the use of a lengthy request form, prohibiting requirements for notarized signatures, and prohibiting requirements that requests be submitted or processed through a portal or API. We also appreciate that OCR is making clear in the regulations that individuals can obtain their health information by e-mail (presumably without the need for the individual to acknowledge a light security warning). With respect to prohibiting imposition of a notary requirement, we urge OCR to be clear that this also applies to requests submitted by personal representatives; we have seen entities requiring notarization when attesting to personal representative status (such as familial relationship, or legal representative status for a decedent). Such personal representatives should not be required to meet a higher standard for identity proofing, beyond also needing to demonstrate their personal representative status with appropriate documentation.

We strongly urge OCR to prohibit entities from insisting that individuals use their own forms, even when those forms are short. When individuals need to gather PHI from multiple places, and to submit rerequest forms in order to make sure their records are up-to-date, having to submit a different form for each location is a burden. Entities should be required to accept any writing from an individual that meets HIPAA (and any applicable state law[8]) requirements – i.e., that includes information needed from the individual to match to records (name, demographic information like date of birth and address), and records sought) versus requiring individuals to complete the entity’s standard, even lightweight form.[9] Those forms should be offered as assistance to individuals seeking their records, not as requirements. Typically, users of Ciitizen have 2-4 providers from whom they are seeking records; individuals with rare disorders on our platform make requests from an average of 7 providers. In general, we have found that most providers will accept a well-crafted request letter versus insisting that individuals use the provider’s own form – but some health care providers do insist on their own forms, and it definitely creates unnecessary hassle in obtaining records. Insisting on a particular form is “form over substance” and is another way that entities create unreasonable obstacles for individuals seeking their PHI.

Too many entities still do not accept requests from individuals by simple e-mail. There is nothing in the HIPAA Privacy Rule that prohibits entities from collecting information from individuals (patients, subscribers) in ways that are convenient for the individual. Today, the only digital pathway that a covered entity is required (either by regulation or guidance) to open to individuals requesting their records is fax. Most requests Ciitizen sends for its users are submitted by fax – but individuals often do not have faxing capabilities. Entities should be required to accept remote access requests from individuals, including by e-mail.

Today the Privacy Rule, consistent with the federal e-SIGN Act, allows entities to accept requests from individuals using a digital signature – but entities are not required to accept a digital signature, which imposes an obstacle to individuals submitting requests remotely. Today, digital signatures are widely acceptable for a broad range of transactions, including establishing bank accounts and nearly every step of a home purchase up to the point of executing closing documents (for example, I submitted the initial offer on a home purchase using Docusign (and that offer was accepted using Docusign); every contract we execute binding Ciitizen, including employment and nondisclosure agreements, is done using Docusign). Refusal to accept a digital signature creates an unreasonable obstacle to individuals trying to access their records.

Finally, we strongly support the express prohibition on the imposition of unreasonable identity verification requirements, but we have concerns that the proposed definition of an unreasonable identity verification measure – one that requires "an individual to expend unnecessary effort or expense when a less burdensome verification measure is practicable for the particular covered entity" – is unlikely to result in much clarity or change in behavior. Most identity verification measures are imposed as risk reduction measures for the entity, which means they may define less burdensome measures that potentially increase some risk for them as "not practicable." We urge OCR to provide more guidance on steps that would be acceptable. For example, is asking individuals to provide a copy of their driver's license (and a birth certificate, in the context of a parent lawfully requesting records of a minor) sufficient? Is it sufficient if a personal health record/application attests to identity proofing using a vendor used by banks or other financial services tools for the opening of accounts remotely? Is it sufficient to identity proof using methods calculated to meet or come close to meeting NIST level of assurance 2 (or conversely, would rejecting this approach constitute an unreasonable measure)? Would a text message, e-mail, or phone call (using information on record with the covered entity) to confirm that the individual made the request be sufficient? Are portal credentials initially granted to an individual sufficient for access through the app or portal? Additional guidance on this topic from OCR will be extraordinarily helpful, both to entities seeking to comply with the rules but also to the public in terms of what they may need to submit in order to obtain records, particularly in remote request scenarios.

Clarification of Fee Provisions (45 CFR 164.524(b)(4) & (d)(6) and page 6469 questions (aa), (dd), (ee), (ff), & (hh), and page 6470 question (ii))

We strongly support the clarification that the individual cannot be charged in circumstances where they request to inspect their PHI in person or when records are sent using an "internet-based method" to the individuals, to a personal health record/application, or, when coming from an "electronic health record," to another health care provider or to any third party. We further ask OCR for additional clarification on what constitutes an "internet-based method." We recommend alignment with ONC's Information Blocking rules, which prohibit fees to individuals (or apps or services acting on their behalf) for "electronic access," which typically involves little to no manual effort to send the record (fees for search and retrieval, in even in an electronic context, have long been prohibited by the Privacy Rule).

Ciitizen also supports the proposed regulatory requirement that entities post fees for individual access, as well as for third party requests with an individual's valid authorization. We also support inclusion in the proposed regulation that individuals be provided with a fee estimate and itemization of charges (currently in guidance but not part of existing regulatory text).

We further urge OCR to be clearer in the regulations regarding the ability of entities to charge up to the maximums established in state law. At Ciitizen we frequently see individuals still being charged state law rates, notwithstanding extensive guidance from OCR on this topic. In particular, state law rates are still frequently applied to requests for paper records. There is a conflict in OCR's guidance between what OCR issued in 2016 - making clear that fees for paper copies must be established in accordance with HIPAA regulations, and that state law rates, often calculated on a per page basis, may result in charges that are significantly higher than what HIPAA allows – and prior guidance from OCR in 2000 indicating that state law per page rates would be considered to meet HIPAA requirements for paper records.[10] Consequently, it is critical for OCR establish more definitive regulatory provisions on this topic. It is not unusual for individuals to be charged hundreds of dollars for their records, calculated based on state law maximums.[11]

OCR should also consider clarification in the regulations of fee provisions as applied to the provision of images to individuals. Images are digital files – frequently very large digital files - yet often cannot be sent to the individual via e-mail due to their size. In our

experience, entities either provide these to individuals for free – or the charges can be quite high. Entities need to be reminded that requests under the individual right of access are subject to fee limitations, including when those images are to be sent to a personal health record/application or to a third party (assuming the definition of "electronic health record" is modified to be clear that it includes records kept by imaging providers). It is possible for entities to establish fee schedules based on the amount of time required to upload images, plus (where applicable) any necessary supplies.

In general, given that the proposed rule carves up the right of access into different "sub-rights" – the right of inspection, the right to access of PHI regardless of format and source (which includes the right to send to the personal health record/application of an individual's choosing), the right to have information from an EHR sent to a third party of the individual's choosing – it is now more challenging to follow which fee provisions apply to which types of access. The chart on page 6465 is helpful – but doesn't account for all of the different pathways to access. We urge OCR to issue further helpful charts and roadmaps to help individuals and entities covered by the Privacy Rule to better navigate this landscape. A chart we developed with AHIMA can be found in Appendix 1.

Requirement to Accept Oral Requests from Individuals to Direct Information in an EHR to 3rd Parties (45 CFR 164.524(d)(1) and page 6469 questions (q), (t), and (v))

HITECH established the right of individuals to have EHI from an EHR sent to the third party of that individual's choice, as long as the information was "clear, conspicuous, and specific." Under the Omnibus Rule, OCR interpreted this HITECH requirement to require a written request from an individual. Now OCR is proposing to require entities to accept "clear, conspicuous, and specific" oral requests from individuals.

Although in general we are supportive of any efforts that are designed to make it easier for individuals to access their PHI – including to send it to the third party of their choice – we have concerns about the potential for abuse when entities are required to process requests to third party designees that are submitted verbally. Historically, OCR minimized the potential for abuse by requiring the execution of HIPAA-compliant authorizations any time a third-party was requesting an individual's PHI. Although one can never be sure that an individual has read through the components of the authorization and fully understands it, at least the opportunity for transparency is present (and the entity has a clear record of having received the individual's authorization).

In this case, the potential for the recipient of this data to claim that the individual is requesting the information is arguably greater when these requests are presented verbally and are required to be honored with simply a verbal request. These concerns are not alleviated when the requests for information are to be submitted by the recipient health care provider or plan. How can the record holder be sure that this is actually a request coming from an individual (particularly in a circumstance where we are also seeking to relax identity verification requirements to make them more accessible to individuals)? Although providers and health plans already can share PHI with one another through one or more of the "treatment, payment, or health care operations provisions," the conditions for one of those provisions must be met or an individual's written authorization would be required to disclose PHI. In this case, by simply claiming the verbal request of an individual, PHI could be shared, regardless of the purpose for the disclosure - which has high potential for abuse. We support that individuals should be allowed to submit only an oral request for inspection of their records (and in this circumstance, the entity should be required to accept that request) – but for information directed to any third parties, it is imperative to take measures to assure that the requests are coming from individuals. Requiring that such requests to have information sent to third parties be in writing does not seem like too great of an obstacle, particularly in light of the potential risks. Individuals obtaining or directing information themselves (or via an app) from a portal or API should not have to provide additional documentation of a request, as this is information that is coming to the individual, via a form/format (personal health record/application) chosen by the individual.

Queries by a Health Care Provider to an HIE for Individual Access Requests (page 6469, question (y))

OCR also specifically asks whether broadcast queries by a health care provider (presumably also by a health plan) to an HIE in response to a request from an individual would be permissible as a customer service activity under health care operations. We support this interpretation. However, OCR should instead consider whether, under a combination of HIPAA and the Information Blocking rules, providers should be required to submit such queries absent application of a legal exemption (beyond contractual prohibitions). No doubt a covered entity must obtain information from a BA - such as an HIE - in order to comply with an individual's request for information where the information required to be provided by the covered entity is held by the BA. But where information in an HIE is often not separable by provider/health plan source – and is all information subject to the HIPAA right of access – and where providers are easily able to query all of this information for treatment purposes, OCR and ONC should explore viable avenues for further leveraging interoperability as one pathway to facilitate easier individual access to health information. (Given that not all providers are connected to HIEs, it is still critical for OCR to modify the Privacy Rule to assure that HIEs can

facilitate providing information directly to patients, consistent with the Cures Act and the Information Blocking rules, versus patients having to rely on their providers to query an HIE.)

Warning Individuals Regarding Use of a Personal Health Record/Application (page 6469, questions (o) & (p))

OCR specifically asks whether entities should be required to provide individuals with notice about the risks of transmission to third parties from an electronic health record. While we do not think such notices should be required (particularly if steps are taken to try to curb potential abuses by third parties, such as requiring a written request from the individual), entities should be permitted to provide such notice as long as they are doing so in a way that does not create unreasonable obstacles to individual access. Notices that are overly long and complicated, that are unduly alarming (emphasizing only risks and not potential benefits), or that require an individual to take an extraordinary number of steps (clicking several boxes) are edging into creating unreasonable obstacles, and this is particularly the case where the individual is seeking to have their information sent to a personal health record/application.[12] (Frankly, in the latter case, education of individuals is far more timely when it takes place before the individual chooses the record or app, not when the individual is trying to get their health information into a record or app they have already chosen.) But some transparency in the context of third party transmissions could be beneficial, including to make sure that the individual authorized the transaction (something which could not take place in a circumstance where a health care provider or plan is seeking records from an EHR and verbally claiming that they are doing so for the individual, at least as currently proposed by OCR).

Miscellaneous questions from OCR regarding the HIPAA Right of Access

OCR has asked a number of questions relevant to its proposed right of access modifications, some of which we have answered in the comments above. We also offer a few thoughts on some of the other access-related questions below:

- Re: intersection with other interoperability programs/laws (page 6468 question (i)): We support the proposed regulatory provision requiring entities to honor a form/format request from an individual in circumstances where that form/format is consistent with technology requirements either imposed on that entity or on the entity's technology vendor (for example, requirements on certified health information technology vendors). We agree this means turning on the functionalities provided with already-purchased technology, so that individuals can take advantage of them. At the same time, individuals should not be required to use these functionalities to access their health information if that is not their

preferred form/format. Requirements by these vendors that personal health records/applications "register" with the vendor must be done in a way that does not exclude a personal health record/application chosen by an individual unless it would raise genuine security risks for the vendor or its covered entity (or BA) customer.

- Summary in lieu of copies (45 CFR 164.524(c)(2)(iv)(B)): We support OCR's proposals to require that when individuals are offered a summary in lieu of copies of their PHI, entities are required to inform the individuals that they retain their rights to get copies of their PHI if a summary would not meet their needs.

(below - Chart on proposed fees jointly developed with AHIMA)

Scenario	Documentation Required for Request?	Can Choose form/format for data?	Fees?	Other
Individual requests to inspect PHI	Written request is permissible but not required. Written request may not impose unreasonable measures		None when in person or via "internet-based" method (no fee to person or to app developer)	
Individual requests PHI (paper or electronic) to be sent to "personal health application"	Written request is permissible but not required. Can also be oral.	Yes – to personal health app	Reasonable, cost-based fees for labor costs of making copy, and cost of preparing summary/explanation (plus any supplies, or postage if applicable) – free if by "internet-based" method	

Scenario	Documentation Required for Request?	Can Choose form/format for data?	Fees?	Other
Individual requests PHI to be sent to self	Entity can ask for request in writing	Yes	Reasonable, cost-based fees for labor costs of making copy, and cost of preparing summary/explanation (plus any supplies, or postage if applicable) – free if by "internet-based" method	
Individual requests PHI to be sent to third party (not from EHR)	Requires HIPAA-compliant authorization – not part of HIPAA right of access	No	Not subject to access fee limitation but sale of data provisions apply (must be a reasonable, cost-based fee to cover the cost to prepare and transmit the	Permissive disclosure – unless third party is individual's health care provider

Scenario	Documentation Required for Request?	Can Choose form/format for data?	Fees?	Other
			PHI (so search & retrieval fees can be included), "or fee otherwise expressly permitted by other law" (state law fees).	

Scenario	Documentation Required for Request?	Can Choose form/format for data?	Fees?	Other
Individual requests ePHI to be sent from EHR to third party	Written request not required (can be oral)	No	Reasonable cost-based fee limited to labor for making the copies (no supplies) (and cost of preparing a summary/explanation), (free if use internet based-method)	
Individual requests ePHI from an EHR to be sent directly to a health care provider or health plan	Written request not required (can be oral)	No	Reasonable cost-based fee limited to labor for making the copies (no supplies) (and cost of preparing a summary/explanation), (free if use internet based-method)	
Third party requests (with individual authorization) not from EHR	Requires HIPAA compliant authorization	No	No limits on fees but sale of data provisions apply (must be a reasonable, cost-based fee to cover the cost to prepare and transmit the PHI (so search & retrieval fees can be included), "or fee otherwise expressly	Permissive disclosure
Scenario	**Documentation Required for Request?**	**Can Choose form/format for data?**	**Fees?**	**Other**

Scenario	Documentation Required for Request?	Can Choose form/format for data?	Fees?	Other
			permitted by other law" (state law fees).	

---

[1] See ONC's Information Blocking Report for examples. https://www.healthit.gov/sites/default/files/reports/info_blocking_040915.pdf

[2] 42 USC 300jj-19(c)&(d) (Section 4006 of the Cures Act) requires that HHS:

- In coordination with OCR, issue guidance to HIEs on best practices "to ensure that the [EHI] provided to patients is (A) private and secure; (B) accurate; (C) verifiable; and (D) … exchanged" pursuant to a patient's authorization where one is required by law. (42 USC 300jj-19(c)(3)). Use "existing authorities to encourage partnerships between [HIEs] and health care providers, health plans, and other appropriate entities with the goal of offering patients access to their [EHI] in a single longitudinal format that is easy to understand, secure, and may be updated automatically"). (42 USC 300jj-19(c)(1))
- In coordination with OCR, "educate health care providers on ways of leveraging the capabilities of [HIEs] (or other relevant platforms) to provide patients with access to their [EHI]" and "clarify misunderstandings by health care providers about using [HIEs] (or other relevant platforms) for patient access to [EHI]." (42 USC 300jj-19(c)(2)(A)&(B))
- In consultation with ONC, promote policies that "ensure that a patient's [EHI] is accessible to that patient and the patient's designees, in a manner that facilitates communication with the patient's health care providers and other individuals, including researchers, consistent with such patient's consent" and promote awareness of the patient's right to access PHI under HIPAA. (42 USC 300jj19(e)(1)(A)&(B)).

Section 4006 also requires ONC and OCR to "jointly promote patient access to health information in a manner that would ensure that such information is available in a form convenient for the patient, in a reasonable manner, without burdening the health care provider involved." (42 USC 300jj-19(d))

[3] For example, see 78 Fed Reg. 5566 at 5599 (January 25, 2013) (the Omnibus Rule).

[4] Section 13400(11) of HITECH.

[5] Of note: arguably the proposed regulatory definition does not preclude an individual's use of an app offered by a covered entity. The individual must be able to control information in the app (versus the covered entity) – but the preamble suggests that an app offered by a covered entity could not meet the definition (see page 6457).

[6] Section 13400(5) of HITECH.

[7] In dicta, the opinion in *CIOX v. Azar* suggests that the original HIPAA statute may no longer be a viable source of authority for additions to the HIPAA regulations ("HHS's power to promulgate additional individual-privacy regulations pursuant to §264(c) thus *arguably* expired long ago…. The court need not definitively resolve the issue. For even if HHS' power to make rules pursuant to §264(c) is alive and well, an agency's general rulemaking authority cannot be used to expand a congressionally imposed restriction." (emphasis added)) We do not believe this language constrains OCR from making further changes in the HIPAA regulations, particularly where the modification arguably does not add new rights but interprets an existing individual right in light of changes in the environment.

[8] Given that HIPAA preempts laws that conflict with, or provide fewer protections, it is unlikely that any state law that imposed greater requirements on individuals seeking to access their own information would still be valid, but we have seen entities requiring consent to release of categories of data often deemed to be more sensitive, citing state law as the source of these requirements.

[9] For example, the Social Security Administration (SSA) has established a single form to be used by individuals seeking to have information sent to SSA for disability determinations. To the best of our knowledge, this form is generally accepted by covered entities. In addition, Ciitizen's request letters are usually accepted by health care providers – but when an entity insists on using its own form (essentially requesting the same information – but on a particular form) – it requires more work for the individual to get their health information, as this form must be filled out each and every time records are requested.

[10] 65 Fed. Reg. 82462, at 82557 (Dec. 28, 2000).

[11] Of note: Fed-Ex Kinkos charges less for one of their employees to make copies for a customer (49 cents per page, which presumably includes labor and supplies) than most of these states establish as their maximum per page fee. This suggests that the state maximum fees include costs other than those permitted under HIPAA.

[12] When the Markle Foundation's Connecting for Health multi-stakeholder group initially developed policies to govern the "Blue Button" functionality, they envisioned a very brief "check in" with the individual to make sure the individual was aware that they were taking sensitive health information outside of a protected environment. Although at the time the Blue Button envisioned providing individuals just with a download capability (versus the capability to upload information to personal health records/applications or to transmit information to third parties), the simplicity of this approach is instructive: (https://www.markle.org/sites/default/files/20100831_dlcapability.pdf, page 8):

Health Records Contain Sensitive Information

If you download sensitive information to a shared or unsecured computer or device, others might see it. You are responsible for protecting the information you are downloading and for deciding with whom to share it. Are you sure you want to download a copy of your personal health information to the computer or device you are using? Yes No Tell Me More